

Содержание

1

Отчёт по CVE в HMS — таблица эксплуатируемости (скан cve.md)

1

1.1

Пояснения по эксплуатируемости

4

E1

— Клиентский драйвер JDBC, не на classpath сервера.

4

E2

— Внутри jar-файлов Kudu, отсутствуют в дереве metastore-server.

4

E3

— HTTP/сервлет-путь отключён по умолчанию.

4

E4

— spring в metastore — только spring-jdbc/tx.

4

E5

— Попадает через packaging, живого пути исполнения нет.

5

E6

— Уязвимый примитив никогда не выбирается (фантомный CRITICAL).

5

E7

— Test-score.

5

E8

— Клиентский TLS-MITM; роль сервера не затронута.

5

E9

— Требуется локальный доступ.

5

E10

— Требуется MITM на пути DNS.

5

E11

— Недоверенный вход не доходит до уязвимого парсера.

5

E12

— Не является HTTP-сервером.

6

1.2

Итог

6

1 Отчёт по CVE в HMS — таблица эксплуатируемости (скан cve.md)

Дата: 6 сентября 2026 · **Объект:** образ Hive Metastore, component-hive-community @ SDP0ZN-2799-fix-cve · **Входные данные:** ~/sdp/component-hive-community/cve.md

Одна строка на просканированную библиотеку. **Приоритет** — это приоритет *устранения* (отдача × трудозатраты), не зависящий от «сырого» CVSS; вердикт о достижимости указан в столбце **Эксплуатируемость**, а его общие пояснения вынесены в сноски **E1-E12** под таблицей. Текстовый анализ — в HMS-CVE-Exploitability-Report.md; данный файл — справочная матрица.

Легенда приоритетов — **P1** сделать в первую очередь (одно изменение закрывает много находок либо единственный CRITICAL; малые трудозатраты) · **P2** сделать при удобном случае (реально достижимо, но несрочно) · **P3** действий в текущем развёртывании не требуется (подавить в сканере с указанным обоснованием; вернуться только при изменении развёртывания).

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
bcprov-jdk18on 1.78.1	CVE-2025-14813	P1 · CRIT	E6
netty-codec 4.1.115 ·	CVE-2026-59901, CVE-2026-42583	P1 · HIGH	E2
hive-kudu-handler			
netty-codec-dns 4.1.115 ·	CVE-2026-42579, CVE-2026-73508	P1 · HIGH	E2
kudu-client			
netty-codec-haproxy 4.1.115 ·	CVE-2026-55851, CVE-2026-48059,	P1 · HIGH	E2
hive-kudu-handler	CVE-2026-44893, CVE-2026-59919		

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
netty-codec-http 4.1.115 · kudu-client	CVE-2026-56745, CVE-2026-55833, CVE-2026-55831, CVE-2026-42587, CVE-2026-42584, CVE-2026-33870, CVE-2026-59921, CVE-2026-59903, CVE-2026-56746, CVE-2026-50020, CVE-2026-42585, CVE-2026-42581, CVE-2026-42580, CVE-2026-41417, CVE-2025-67735, CVE-2025-58056	P1 · HIGH	E2
netty-codec-http2 4.1.115 · kudu-client	CVE-2026-56819, CVE-2026-42587, CVE-2026-33871, CVE-2025-55163, CVE-2026-50560, CVE-2026-48043, CVE-2026-47244	P1 · HIGH	E2
netty-codec-mqtt 4.1.115 · hive-kudu-handler	CVE-2026-44248	P1 · MED	E2
netty-codec-redis 4.1.115 · kudu-client	CVE-2026-50011, CVE-2026-48006, CVE-2026-44890, CVE-2026-44250, CVE-2026-56818, CVE-2026-42586	P1 · HIGH	E2
netty-codec-smtp 4.1.115 · hive-kudu-handler	CVE-2025-59419	P1 · HIGH	E2
netty-codec-stomp 4.1.115 · kudu-client	CVE-2026-44891, CVE-2026-59920	P1 · HIGH	E2
netty-codec-xml 4.1.115 · hive-kudu-handler	CVE-2026-73507, CVE-2026-56817	P1 · HIGH	E2
netty-common 4.1.115 · hive-kudu-handler	CVE-2025-25193	P1 · MED	E2
netty-handler 4.1.115 · hive-kudu-handler	CVE-2026-50010, CVE-2026-45416, CVE-2026-44249, CVE-2025-24970	P1 · HIGH	E2
netty-handler-proxy 4.1.115 · kudu-client	CVE-2026-42578	P1 · LOW	E2
netty-handler-ssl-ocsp 4.1.115 · kudu-client	CVE-2026-56822, CVE-2026-56821, CVE-2026-56820	P1 · HIGH	E2
netty-resolver-dns 4.1.115 · hive-kudu-handler	CVE-2026-47691, CVE-2026-45674, CVE-2026-45673	P1 · HIGH	E2
netty-transport-sctp 4.1.115 · kudu-client	CVE-2026-59902, CVE-2026-46340	P1 · HIGH	E2
libthrift 0.16.0	CVE-2026-43869	P2 · HIGH	E8
commons-lang 2.6 · hive-jdbc-standalone	CVE-2025-48924	P3 · MED	E1
jackson-core 2.17.0 · hive-jdbc-standalone	GHSA-72hv-8253-57qq	P3 · HIGH	E1

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
jackson-databind 2.17.0 · hive-jdbc-standalone	CVE-2026-54512, CVE-2026-54513, CVE-2026-54514, CVE-2026-54515, CVE-2026-59888	P3 · HIGH	E1
jetty-security 9.4.58 · hive-jdbc-standalone	CVE-2026-10050	P3 · HIGH	E1
jetty-server 9.4.58 · hive-jdbc-standalone	CVE-2026-6790	P3 · MED	E1
jjwt-impl 0.10.5 · hive-jdbc-standalone	jjwt/jjwt#930 (без CVE)	P3 · MED	E1
protobuf-java 3.7.1 · hive-jdbc-standalone	CVE-2024-7254, CVE-2022-3510, CVE-2022-3509, CVE-2022-3171, CVE-2021-22570, CVE-2021-22569	P3 · HIGH	E1
jetty-http 9.4.58	CVE-2026-2332, CVE-2024-6763	P3 · HIGH	E3
pac4j-core 4.5.10	CVE-2026-40458	P3 · HIGH	E3
nimbus-jose-jwt 9.37.2	CVE-2025-53864	P3 · MED	E3
okio 2.8.0	CVE-2023-3635	P3 · MED	E3
spring-core 5.3.39	CVE-2025-41249, CVE-2026-41848	P3 · HIGH	E4
spring-context 5.3.39	CVE-2025-22233, CVE-2024-38820	P3 · MED	E4
spring-expression 5.3.39	CVE-2026-41851, CVE-2026-41852	P3 · LOW	E4
hive-exec 4.0.0	CVE-2024-29869	P3 · MED	E5
kafka-clients 2.5.0	CVE-2026-33558, CVE-2024-31141, CVE-2021-38153	P3 · MED	E5
bcprov-jdk15on 1.68	CVE-2024-34447, CVE-2024-30171, CVE-2024-29857, CVE-2023-33202, CVE-2023-33201	P3 · MED	E7
guava 22.0 · hive-exec / прямая зависимость	CVE-2018-10237, CVE-2020-8908, CVE-2023-2976	P3 · MED	E9
guava 30.1.1 ·	CVE-2020-8908, CVE-2023-2976	P3 · MED	E9
hadoop-shaded-guava 1.1.1			
hadoop-common 3.3.6	CVE-2024-23454	P3 · LOW	E9
dnsjava 2.1.7	CVE-2024-25638	P3 · HIGH	E10
commons-compress 1.23.0	CVE-2024-26308, CVE-2024-25710, CVE-2023-42503	P3 · MED	E11
commons-configuration 1.10	CVE-2025-46392	P3 · LOW	E11
commons-configuration2 2.8.0	CVE-2026-45205, CVE-2024-29133, CVE-2024-29131	P3 · MED	E11
commons-lang3 3.12.0 · hive-exec / прямая зависимость	CVE-2025-48924	P3 · MED	E11
commons-lang3 3.14.0 ·	CVE-2025-48924	P3 · MED	E11
ozone-file-system-hadoop3			
javax.el 3.0.0	CVE-2021-28170	P3 · MED	E11

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
netty-codec-http 4.1.136 · ozone-file-system-hadoop3	CVE-2026-59903	P3 · MED	E12

1.1 Пояснения по эксплуатируемости

Metastore выполняется как HiveMetaStore с classpath = conf + /opt/hive/lib/* и только он (hive-entriypoint.go, функция buildClasspath); Thrift-сервер по умолчанию **бинарный** (metastore.server.thrift.transport.mode=binary), сервлет свойств отключён (hive.metastore.properties.servlet.disable=true).
1).

E1 — Клиентский драйвер JDBC, не на classpath сервера.

Находка лежит в /opt/hive/jdbc/hive-jdbc-...-standalone.jar, который процесс metastore никогда не загружает (CP="/etc/hive/conf:/opt/hive/lib/*"). Значима только для *клиентского* процесса, запускающего JDBC-драйвер, но не для сервера metastore. Для образа сервера — подавить.

E2 — Внутри jar-файлов Kudu, отсутствуют в дереве metastore-server.

Все эти модули netty 4.1.115 вшиты (shaded) в kudu-client-1.18.1 / hive-kudu-handler, которых **нет** в дереве зависимостей metastore-server — они попадают в /opt/hive/lib через полный tar-архив сборки Hive. Metastore никогда не открывает соединение с Kudu, поэтому ни один netty-канал из этих jar не создаётся; собственная netty metastore — **4.1.137** (исправлено). **Удаление двух jar-файлов Kudu закрывает всю эту группу** (~40 находок) при нулевой потере функциональности.

E3 — HTTP/сервлет-путь отключён по умолчанию.

Jetty-слушатель, проверка JWT/JWKS (nimbus, okio через okhttp) и аутентификация сервлета pac4j достижимы только при thrift.transport.mode=http (по умолчанию binary) или properties.servlet.port ≥ 0 (по умолчанию -1). В конфигурации по умолчанию HTTP-фронта нет, поэтому ничего из этого не срабатывает. Становятся реальными **только** при явном включении оператором HTTP-транспорта или сервлета свойств — это следует задокументировать.

E4 — spring в metastore — только spring-jdbc/tx.

spring-core используется исключительно слоем транзакций (JdbcTemplate, TransactionContext). Уязвимые функции не задействованы: spring-security @EnableMethodSecurity отсутствует в дереве и в исходниках (CVE-2025-41249), а spring-context/spring-expression **вообще нет** в дереве metastore-server (попадают через packaging, не загружаются), так что для их CVE в DataBinder/SpEL нет достижимой точки вызова.

E5 — Попадает через packaging, живого пути исполнения нет.

hive-exec (в HMS нет движка запросов) и kafka-clients (metastore ничего не отправляет в Kafka) **отсутствуют** в дереве metastore-server. Присутствуют в /opt/hive/lib через полный tar-архив Hive, но ни один путь исполнения в HiveMetaStore их не загружает.

E6 — Уязвимый примитив никогда не выбирается (фантомный CRITICAL).

BouncyCastle присутствует в runtime-classpath, но CVE-2025-14813 — в режиме **GOST 28147 CTR** (повторное использование гаммы после 255 блоков). HMS в TLS/SASL/PKI использует стандартные AES/RSA/ECDSA и никогда не выбирает GOST 28147, поэтому уязвимый код не инстанцируется. CRITICAL по CVSS, но фантом для данного развёртывания — **всё же обновить до 1.84**, чтобы закрыть сканер и CVE-2026-0636/5588 (малые трудозатраты, высокая отдача по гигиене сканера → P1).

E7 — Test-scope.

bcprov-jdk15on 1.68 — зависимость **test-scope** в дереве metastore-server (через hive-shims → тестовые jar hadoop-yarn). В runtime используется bcprov-jdk18on-1.78.1. Исключить линейку 1.5-on из packaging.

E8 — Клиентский TLS-MITM; роль сервера не затронута.

CVE-2026-43869 — отсутствие **проверки имени хоста TLS в Thrift-клиенте** (CWE-297), то есть слабость клиента при наличии сетевого MITM. Metastore — концевой **сервер**; его единственное исходящее соединение — JDBC к СУБД, а не Thrift/TLS. Это не ошибка парсинга/RCE/DoS — вредоносный клиент, отправляющий сформированные Thrift-пакеты, этим воспользоваться не сможет. Обновить до 0.23.0 ради корректности клиентских jar (P2), для сервера не срочно.

E9 — Требуется локальный доступ.

Доступный на чтение всем временный каталог / Files.createTempDir (guava) и локальное раскрытие временного файла (hadoop-common) требуют **локального** доступа к контейнеру, а не удалённого клиента.

E10 — Требуется MITM на пути DNS.

Обход DNSSEC в dnsjava требует атакующего на пути DNS; разрешение имён только внутри кластера. Совпадает с мерами митигации, уже зафиксированными для Ozone.

E11 — Недоверенный вход не доходит до уязвимого парсера.

Это ошибки DoS/парсинга (неконтролируемая рекурсия, StackOverflow, вычисление EL), требующие управляемого атакующим входа в **конкретный** метод. Metastore разбирает собственную доверенную конфигурацию; javax.el достижим только через cron-utils для заданных администратором расписаний. Ни один путь от недоверенного клиента в эти парсеры не ведёт.

E12 — Не является HTTP-сервером.

CVE-2026-59903 — отравление кэша через CORS Vary, что относится к HTTP-**серверу**. Копия netty-codec-http 4.1.136 здесь — это Ozone FS-клиент (ozone-fs-hadoop3), который HTTP-сервером не является.

1.2 Итог

- **P1 (в первую очередь):** удалить hive-kudu-handler + kudu-client из образа (закрывает всю группу netty-4.1.115, ~40 находок) и обновить bcprov-jdk18on 1.78.1 → 1.84 (закрывает единственный CRITICAL). Обе задачи малозатратны.
- **P2 (при удобном случае):** libthrift → 0.23.0 ради корректности клиентских jar.
- **P3 (действий в текущем развёртывании не требуется):** всё остальное — подавить в сканере с применимой сноской E-, и вернуться только при включении HTTP-транспорта / сервлета свойств.

Примечание: очевидные опечатки OCR в исходном скане исправлены (VE-2026-... → CVE-2026-...); ссылки на бюллетени без CVE (jackson-core GHSA-72hv-8253-57qq, jjwt #930) оставлены как есть. Вердикты о происхождении (в дереве или только в сборке) получены из `mvn dependency:tree -pl standalone-metastore/metastore-server`.